



Clark 시스템 구성도

아이지넷(마이데이터 사업자) × 더파트너스(GA사) 분리 아키텍처 — 컴플라이언스 반영

2026-05-14

아이지넷 NCP

더파트너스 AWS 서울 리전

v4.0

목차

🏛️ 컴플라이언스 핵심 규칙

📖 전체 구성도

🏢 회사별 인프라

🔒 CI 관리 정책

🗣️ LLM 방안

📄 보험 진단 흐름

💬 채팅 AI 대화 흐름

☎️ 상담 신청·철회 흐름

🛡️ 보안 정책

⚖️ 최종 법적 판정



컴플라이언스 핵심 규칙

절대 금지

🔒 CI 외부 전송 금지

CI(연계정보) 단방향 암호화 값은 **아이지넷 내부 DB에서만** 관리합니다. 더파트너스·GA 사·원수사 등 외부로 절대 전송하지 않습니다.

목적: 탈퇴 후 재가입 시 동일인 확인 (중복

반드시 선택

🗣️ LLM은 국내 서버 운영 필수

AI LLM이 해외 서버를 경유하면 **개인정보 국외 이전** 규제 적용. 아래 3가지 방안 중 반드시 1개 선택해야 합니다.

① AWS Bedrock (서울 리전) ← 1순위

절대 금지

🚫 마이데이터 + AI 직접 결합 금지

아이지넷이 수집한 **마이데이터를 AI(LLM)에 직접 입력하는 구조** 불가능합니다.

신용정보법: 마이데이터는 동의 목적 범위 내에서만 활용

가입 방지)

보관: 탈퇴 후 1년 후 자동 파기

② HyperCLOVA X (네이버) ← 2순위

③ Azure OpenAI (한국 중부) ← 3순위

→ 아이지넷은 데이터 전달만, 더파트너스 (GA사)가 AI 분석 담당으로 역할 분리 필수

동의 필수

건강 데이터 별도 동의

건강 검진 정보는 민감정보(개인정보보호법 제23조)로 분류됩니다.

일반 개인정보 동의와 반드시 분리된 별도 동의 화면 필요.

더파트너스 전송 시 더파트너스 명시 필수.
미동의 시에도 기본 서비스(마이데이터) 이용 가능해야 함.

허용

더파트너스(GA사) AI 보험 분석

더파트너스는 GA사(법인보험대리점)로 보험업법상 보험모집 허가 주체입니다.

→ KC카드 기반 LLM 보험 보장 분석 적법
→ 아이지넷 혁신금융 검수 범위에서 AI 서비스 제외 가능
→ 단, 면책 고지 화면 표시 필수

운영 기준

상담 철회 시 DB 즉시 회수

사용자가 상담을 철회하면 GA사/원수사에 철회 API 즉시 호출, 삭제 완료 응답(timestamp) 수신 후 감사 로그에 기록해야 합니다.

SLA: 24시간 이내 삭제 완료
완료 후 사용자에게 삭제 완료 알림 발송

운영 기준

GA 배분 알고리즘 공정성

더파트너스(자회사)가 GA 배분 대상이 될 수 있어 공정거래법상 이해충돌 이슈 주의.

→ 배분 알고리즘 객관적 기준 문서화
→ 더파트너스 배분 시 "자회사입니다" 고지 의무
→ 더파트너스 우선 배분 조항 없음을 명시

허용

원수사 직접 DB 제공

마이데이터 사업자는 사용자 동의 기반 제3자 제공이 합법입니다.

기존 플랫폼에서 이미 운영 중인 검증된 구조.
동의 화면에 원수사명·제공항목·보존기간 명시 필수.

가드레일 필수

채팅 AI — 범위 밖 질문 차단

채팅 UI에서 어떤 질문이든 입력될 수 있어 범위 밖 답변이 생성될 경우 보험업법·금소법 저촉 위험이 있습니다.

차단 대상: 상품 추천 / 보험 비교 / 보험료 예측 / 가입 권유

차단 시 응답: "전문 상담사와 직접 상담을 권장합니다"로 유도

허용 범위: 현재 보장 현황 분석·공백 안내에 한정

면책 고지 필수

💬 생성형 AI 답변 — 면책 고지 상시 표시

생성형 AI가 자유롭게 답변할 경우 잘못된 보험 정보 제공 시 금소법 설명의무 위반 가능성이 있습니다.

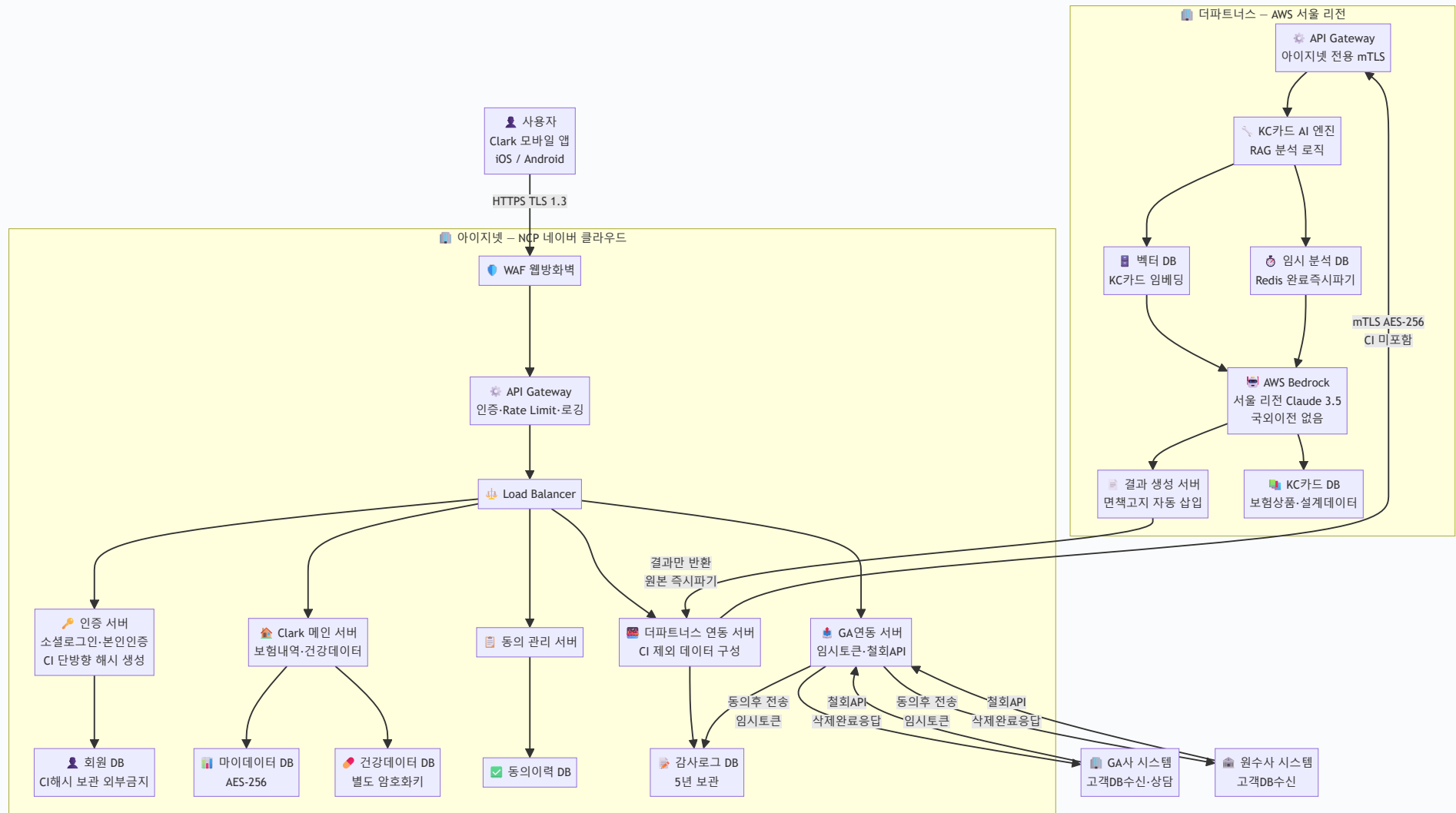
모든 AI 답변 하단 상시 표시:

"이 답변은 AI가 생성한 정보로 정확성을 보장하지 않습니다. 보험 가입 전 전문 설계사와 상담하시기 바랍니다."

채팅 대화 내용은 개인정보에 해당 — 보관
기간·파기 정책 수립 필요



전체 시스템 구성도



회사별 인프라 구성

아이지넷 — NCP (네이버 클라우드 플랫폼)

보험 마이데이터 사업자 | Clark 앱 운영

DMZ 존

- ▶ WAF (웹 방화벽) — SQL Injection, XSS 방어
- ▶ API Gateway — JWT 인증, Rate Limiting, 요청 로깅
- ▶ Load Balancer — 트래픽 분산 및 헬스체크

서비스 존 (사실망)

- ▶ 인증 서버 — 소셜로그인(OAuth2+PKCE), 본인인증, CI 해시 생성
- ▶ Clark 메인 서버 — 마이데이터 처리, 건강데이터 연동
- ▶ 동의 관리 서버 — 약관 버전 관리, 철회 처리
- ▶ 더파트너스 연동 서버 — CI 제외 전송, mTLS 암호화, 결과 수신
- ▶ GA/원수사 연동 서버 — 고객DB 전송, 임시 토큰, 철회 API

데이터 존 (최고 보안 등급)

- ▶ 회원 DB — CI 단방향 해시 (외부 절대 미전송)
- ▶ 마이데이터 DB — 보험 가입 내역 (AES-256 암호화)
- ▶ 건강 데이터 DB — 프롬에이지 연동 (별도 암호화 키, 민감정보)
- ▶ 동의 이력 DB — 약관 동의 버전·일시 (분쟁 증빙)
- ▶ 감사 로그 DB — 전송·접근·삭제 이력 (5년 보관)

더파트너스 — AWS 서울 리전 (ap-northeast-2)

GA사 (법인보험대리점) | KC카드 기반 AI 엔진 운영

DMZ 존

- ▶ API Gateway — 아이지넷 전용 mTLS 엔드포인트
- ▶ IP 화이트리스트 — 아이지넷 서버 IP만 접근 허용

서비스 존

- ▶ KC카드 AI 분석 엔진 — 분석 데이터 수신, RAG 쿼리 생성
- ▶ 벡터 DB (OpenSearch) — KC카드 데이터 임베딩 저장·검색
- ▶ **AWS Bedrock (서울 리전)** — Claude 3.5 추론, 국외 이전 없음
- ▶ 결과 생성 서버 — 텍스트+이미지 조합, 면책고지 자동 삽입

데이터 존

- ▶ KC카드 DB (RDS) — 보험 상품·설계 데이터 영구 보관
- ▶ 임시 분석 DB (Redis) — 처리 중만 보관, **완료 즉시 파기**
- ▶ **CI 데이터 저장 없음**

AWS BEDROCK 선택 이유

- ▶ 더파트너스 기존 AWS 인프라와 즉시 통합 가능
- ▶ 서울 리전 → 데이터가 한국 서버에서만 처리
- ▶ 개인정보 국외 이전 이슈 없음
- ▶ 엔터프라이즈: 입력 데이터 AI 학습 사용 차단

외부 연동

- ▶ 마이데이터 표준 API — 금융결제원, 보험개발원 (OAuth2+mTLS)
- ▶ 프롬에이지 API — 메디에이지, 건강검진 (별도 동의 후)
- ▶ 소셜 로그인 — 카카오, 네이버, 애플
- ▶ 본인인증 — PASS, 아이핀



CI(연계정보) 관리 정책

사용자 본인인증

PASS / 아이핀



아이지넷 인증 서버에서
SHA-256 단방향 해시 생성 (salt 포함)



원본 CI 즉시 폐기



❌ 절대 금지 — 외부 전송

더파트너스 (KC카드 AI 엔진) → 전송 금지

GA사 → 전송 금지

원수사 → 전송 금지

기타 모든 외부 시스템 → 전송 금지

✅ 허용 사용 목적

재가입 시 동일인 여부 확인 (중복 가입 방지)

아이지넷 회원 DB
단방향 해시값만 저장
탈퇴 후 1년 보관 → 자동 파기

부정 이용 방지
이 외 용도 사용 금지

개인정보처리방침 명시 필수

"탈퇴 후에도 재가입 방지 목적으로 본인인증 연계정보(CI)의 단방향 암호화 값을 탈퇴일로부터 1년간 보관합니다."

AI LLM 인프라 방안 (3가지 중 선택 필수)

⚠ 해외 LLM API 직접 호출 시 개인정보 국외 이전 규제 적용. 아래 3가지 중 반드시 1개를 선택하여 국내 서버에서 LLM을 운영해야 합니다.

★ 1순위 권고

AWS Bedrock (서울 리전)

더파트너스가 기존에 사용 중인 AWS 환경에서 바로 활성화. 서울 리전(ap-northeast-2)에서 LLM을 운영하므로 데이터가 한국 서버 내에서만 처리됩니다.

- ✓ 더파트너스 기존 AWS 인프라 즉시 활용
- ✓ 국외 이전 없음, 규제 가장 깨끗
- ✓ Claude 3.5 / Llama 3 등 선택 가능
- ✓ 초기 구축 비용 없음 (API 과금)

⚠ 서울 리전 지원 모델 목록 사전 확인 필요

2순위

HyperCLOVA X (네이버)

네이버가 운영하는 국내 LLM. 완전 국내 서버 운영으로 규제 관점에서 가장 안전한 구조입니다.

- ✓ 규제 관점 가장 안전
- ✓ 한국어 특화 모델
- ✓ 금융 서비스 레퍼런스 보유

⚠ 글로벌 LLM 대비 성능 검토 필요
⚠ KC카드 도메인 파인튜닝 추가 필요

3순위

Azure OpenAI (한국 중부)

Microsoft Azure 한국 중부 리전에서 GPT-4o 등 OpenAI 모델 사용. 데이터가 한국 서버에서 처리됩니다.

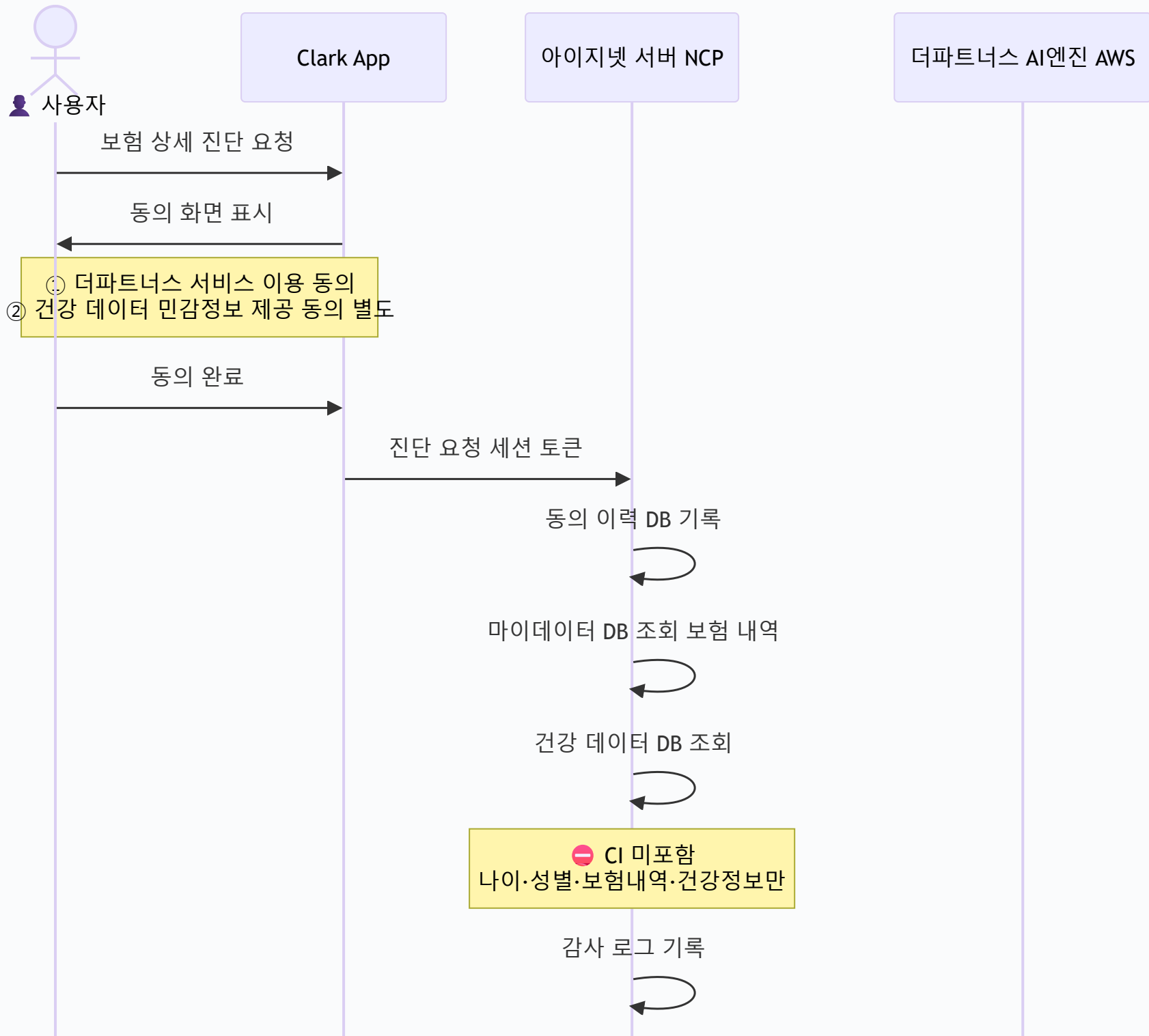
- ✓ GPT-4o 등 OpenAI 최신 모델
- ✓ 국외 이전 없음
- ✓ 엔터프라이즈 데이터 보호 계약

⚠ 더파트너스 AWS 외 Azure 추가 계약 필요
⚠ 아키텍처 복잡도 증가

💡 **KC카드 AI 엔진 구조 (RAG 방식):** KC카드 데이터를 벡터 DB에 임베딩 → 사용자 분석 데이터 입력 → Bedrock이 KC카드 DB 검색 + 분석 데이터 조합 → 보험 보장 분석 결과 생성



보험 상세 진단 요청 흐름



mTLS + AES-256 암호화 전송

임시 DB 저장 Redis

KC카드 벡터 DB 검색 RAG

AWS Bedrock 호출 서울리전

분석 결과 생성

면책 고지 자동 삽입

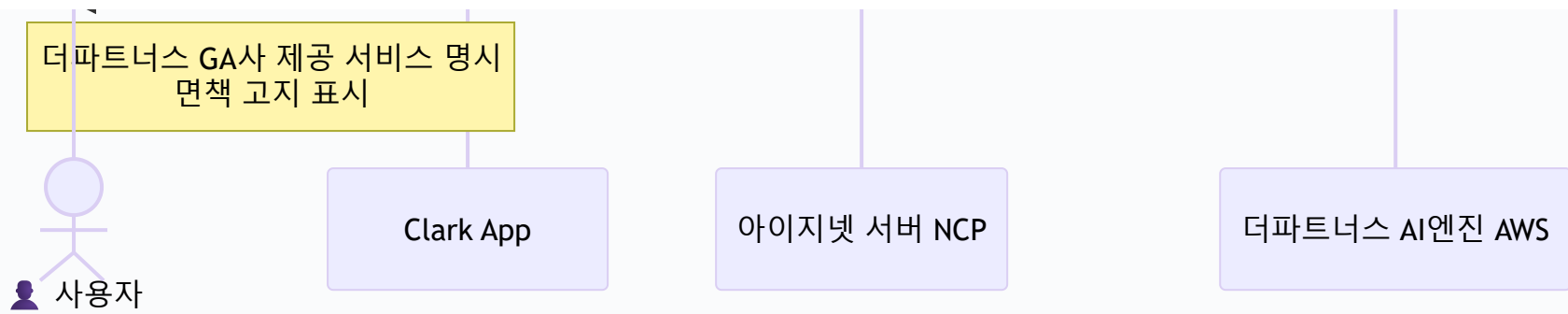
임시 데이터 즉시 파기

분석 결과 반환 텍스트+이미지

수신 로그 기록

결과 전달

보험 진단 화면 표시



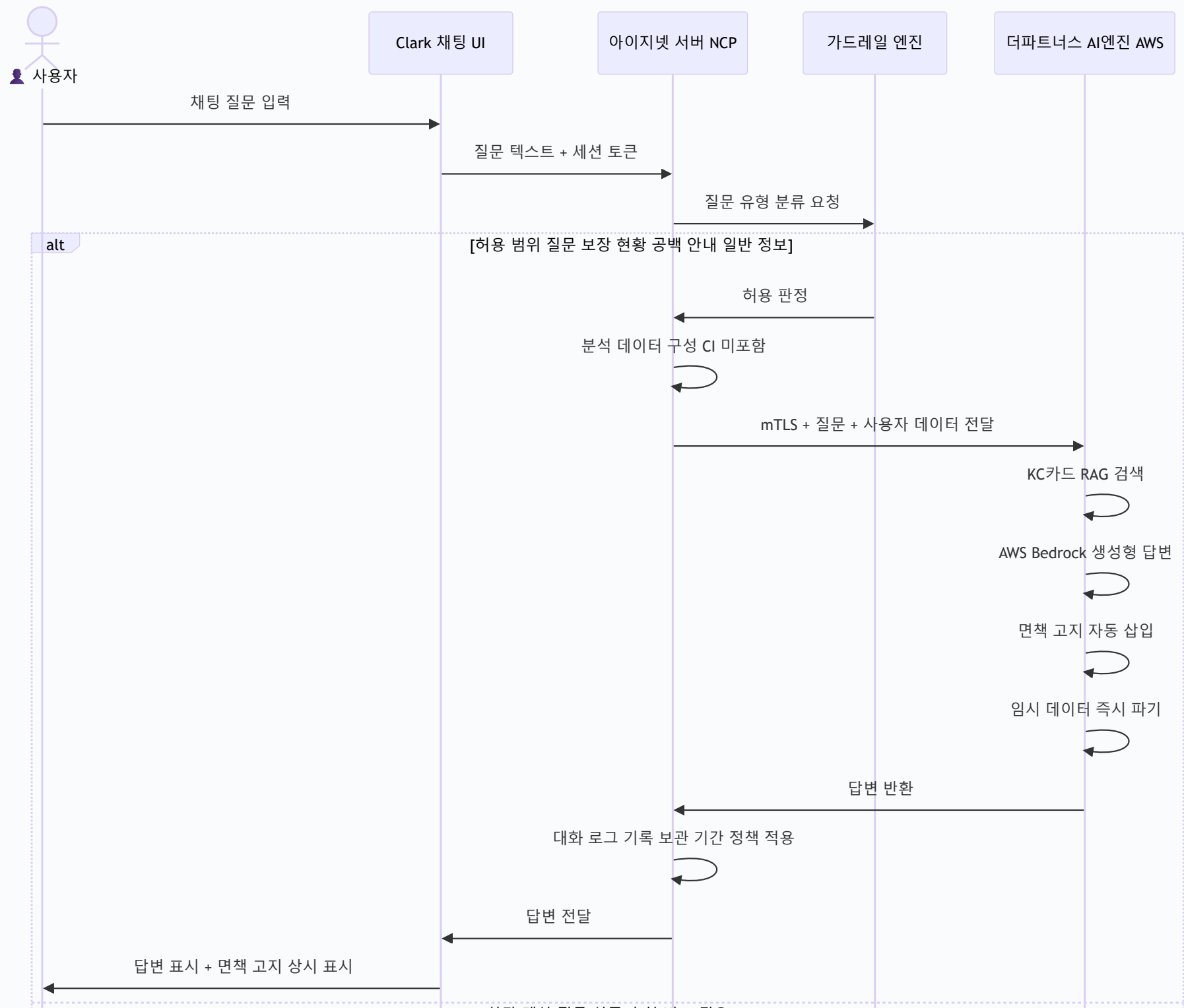
💬 채팅 AI 대화 흐름 — 가드레일 적용

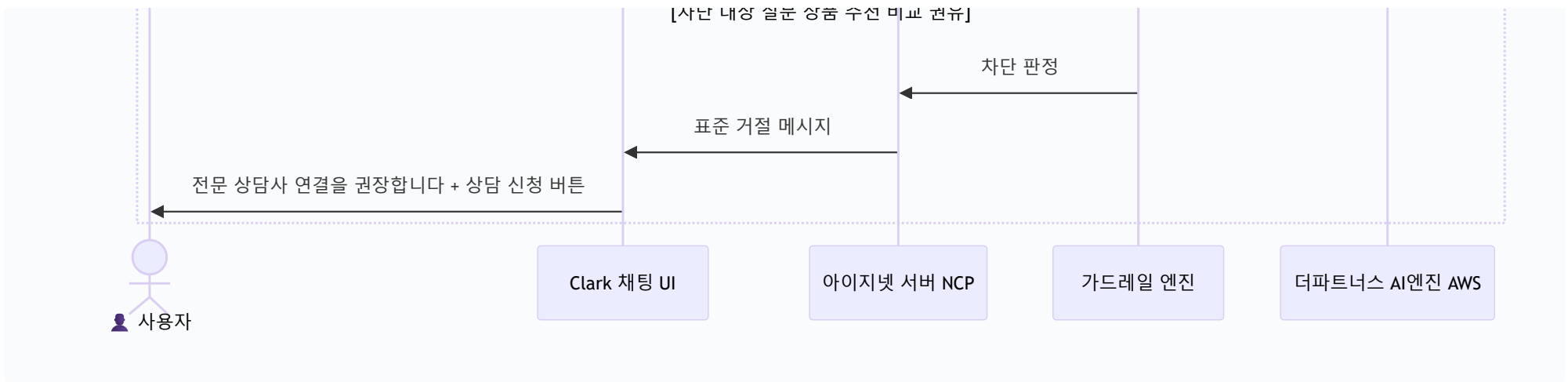
⚠️ 채팅 UI는 사용자가 어떤 질문이든 입력 가능하므로, 가드레일 없이 생성형 AI가 자유롭게 답변하면 서비스 범위(상품 추천·비교·권유 등)를 벗어난 답변이 생성될 수 있습니다. 이 경우 보험업법·금소법 저촉 위험이 발생합니다.

질문 유형별 처리 방침

질문 예시	분류	처리 방침	법적 근거
"내 보험 보장이 어떻게 돼요?"	허용	KC카드 RAG 기반 보장 현황 분석 답변	GA사 허가 범위 내
"보장 공백이 어디 있나요?"	허용	현재 가입 내역 기반 공백 안내	GA사 허가 범위 내
"실손 청구는 어떻게 해요?"	허용	일반 정보 안내 (생성형 답변 + 면책 고지)	정보 제공 수준
"어떤 보험 들면 좋아요?"	차단	"전문 상담사 연결을 권장합니다"로 유도	상품 추천 = 서비스 범위 외
"OO보험 vs XX보험 비교해줘"	차단	"전문 상담사 연결을 권장합니다"로 유도	보험 비교 = 서비스 범위 외

질문 예시	분류	처리 방침	법적 근거
"지금 보험 해지하고 갈아타야 할까요?"	차단	"전문 상담사 연결을 권장합니다"로 유도	보험 권유 → 보험업법·금소법 저촉 위험





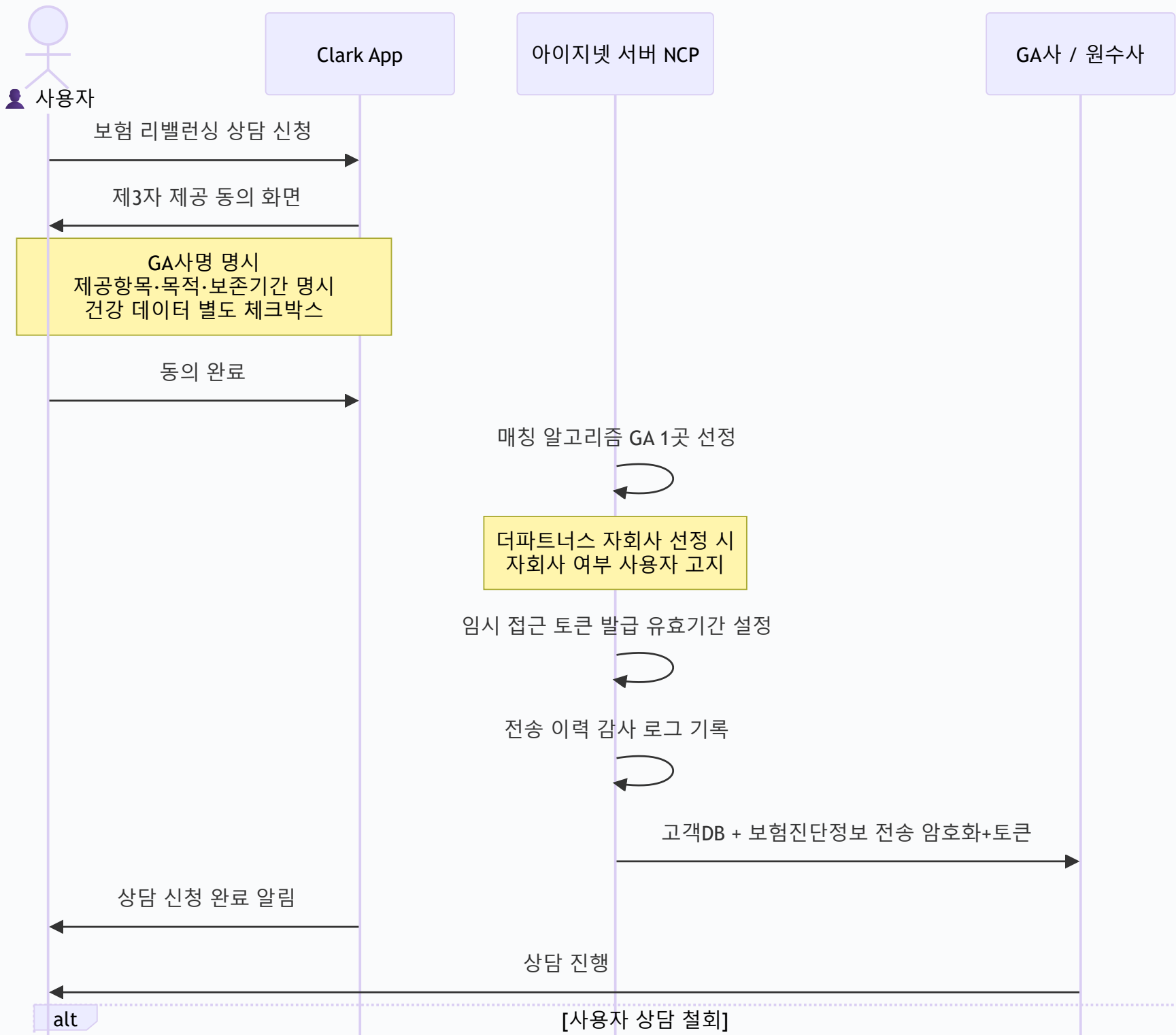
⚠ 채팅 대화 로그 = 개인정보

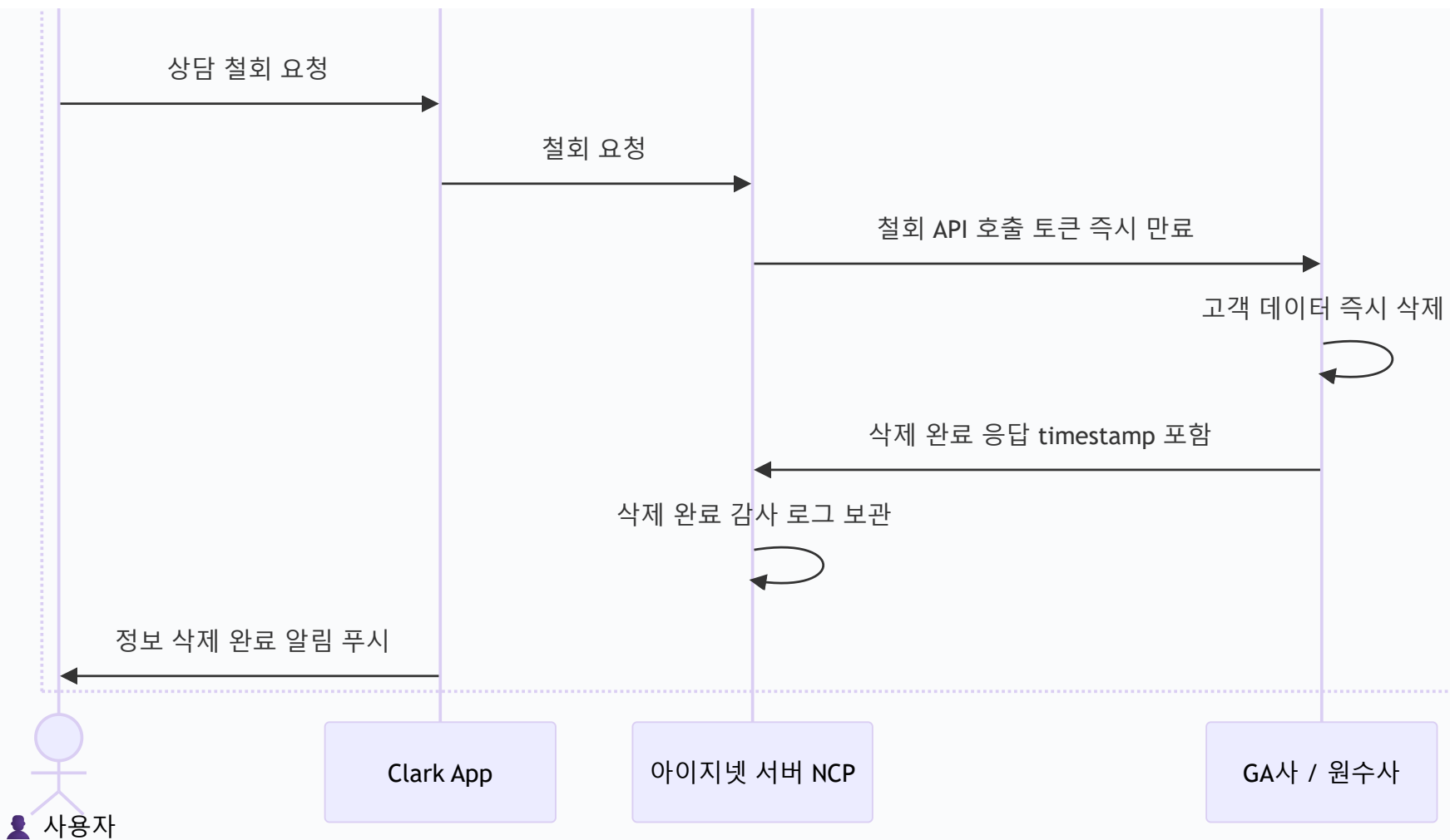
질문·답변 내용이 개인 식별 정보와 결합 시 개인정보에 해당
 보관 기간·파기 정책 별도 수립 → 개인정보처리방침 반영 필요
 더파트너스 서버에 대화 로그 장기 보관 금지 (분석 완료 즉시 파기)
 사용자에게 대화 이력 삭제 기능 제공 권장

✅ 면책 고지 표시 기준

모든 AI 답변 하단에 면책 고지 상시 표시
 채팅 UI 상단에 "AI 서비스 / 더파트너스(GA사) 제공" 명시
 가드레일 차단 시 상담사 연결 CTA 버튼 노출
 면책 고지 최종 문구: 법무팀 확정 필요

☎ 상담 신청 및 철회 흐름





보안 정책 요약

구간	보안 방식	핵심 포인트	상태
사용자 ↔ 아이지넷	TLS 1.3 + Certificate Pinning	앱 내 인증서 고정으로 중간자 공격 방어	필수
아이지넷 DMZ	WAF → API GW → LB 순차 통과	SQL Injection, XSS, 비정상 트래픽 차단	필수
아이지넷 서비스 ↔ DB	사설망 전용 + 최소 권한 계정	DB 직접 접근 불가, 서비스 계정만 허용	필수
아이지넷 DB 암호화	AES-256 컬럼 암호화	건강 데이터는 별도 암호화 키 관리	필수
아이지넷 ↔ 더파트너스	mTLS 상호인증 + AES-256	CI 미포함, 세션 토큰으로 매핑	CI 전송 금지
더파트너스 LLM 호출	AWS Bedrock (서울 리전)	데이터가 한국 서버 내에서만 처리	국외이전 없음
더파트너스 임시 데이터	Redis In-Memory TTL 설정	분석 완료 즉시 파기, CI 데이터 없음	즉시 파기
아이지넷 ↔ GA/원수사	TLS + 임시 접근 토큰	유효기간 설정, 철회 시 즉시 만료	필수
상담 철회	철회 API + 삭제 완료 timestamp	24시간 이내 삭제 SLA, 감사 로그 보관	SLA 협의
감사 로그	전송·접근·삭제 이력 전체 기록	5년 보관 (법정 보존 기간)	필수

 최종 법적 판정 — 기관별 검토 결과

 이 구조로 사업하는 데 법적 문제 없습니다

감독 기관	검토 항목	최초 우려	최종 판정	근거
신용정보원 (신정원)	마이데이터 → 더파트너스 전달	유권해석 필요	해소	업무 위탁 구조로 분류 — 제3자 제공 아님 위탁 계약서 + 처리방침 공개로 처리
금융감독원 (금감원)	GA 배분 행위의 보험모집 해당 여부	유권해석 필요	해소	기존 앱에서 동일 구조로 이미 사업 운영 중 법적으로 검증된 구조
혁신금융위	Phase 1 서비스의 규제 충돌 여부	확인 권장	불필요	아이지넷: 마이데이터 허가 범위 내 더파트너스: GA 업무 범위 내 AI 활용
금융보안원	마이데이터 보안 요건, 망 분리	확인 필요	충족	mTLS·AES-256·망 분리·CI 외부 미전송 모두 설계에 반영됨
개인정보보호 위	민감정보·CI·철회권·국외이전	확인 필요	충족	건강 데이터 별도 동의, 철회 API, AWS Bedrock 서울 리전(국외 이전 없음)
보험업법 (금융위)	AI 보험 분석의 보험모집 해당 여부	위험	안전 (GA사 운영)	더파트너스 = GA사(법인보험대리점) → 보험업법상 보험모집 허가 주체 보장 현황 분석·공백 안내 수준 = 보험모집 비해당

📋 사업 착수 전 처리할 것 (유권 해석 아닌 내부 절차)

계약서

📄 업무 위탁 계약서 체결

아이지넷 ↔ 더파트너스 간 AI 분석 업무 위탁 계약서 작성.

처리방침

📄 개인정보처리방침 업데이트

아이지넷 개인정보처리방침에 추가 명시 필요:

고지 문구

⚠️ AI 면책 고지 문구 확정

더파트너스 AI 분석 결과 화면 하단 상시 표시:

필수 포함 조항:

- 위탁 업무 범위 명시 (보험 보장 분석에 한정)
- 목적 외 이용 금지
- 분석 완료 후 데이터 즉시 파기 의무
- 재위탁 금지

- 더파트너스 위탁 현황 (위탁 업무, 수탁자명)
- CI 단방향 해시 탈퇴 후 1년 보관 목적·기간
- 건강 데이터 민감정보 처리 근거
- GA/원수사 제3자 제공 현황

"본 분석 결과는 일반적인 정보 제공 목적이며, 금융 조연·보험 권유가 아닙니다. 보험 가입 결정 전 전문 설계사와 상담하시기 바랍니다."

법무팀 최종 문구 확정 필요

동의 화면

✓ 건강 데이터 별도 동의 화면

프롬에이지 건강 데이터 연동 시 일반 동의와 분리된 별도 동의 화면 필수.

- 더파트너스 전송 시 더파트너스명 명시
- 미동의 시에도 마이데이터 서비스 이용 가능 명시
- 민감정보임을 사용자에게 고지